

The Redemption - AWS EKS SRE Assessment

Executive design for a global hotel point deduction microservice with zero-downtime target, flash-sale scaling, and defense-in-depth controls.

Executive Summary

- Runs on Amazon EKS across three AZs with private worker nodes and public ingress through CloudFront, WAF, and ALB.
- Uses warm on-demand baseline plus HPA (CPU, memory, RPS) and Karpenter for flash-sale bursts.
- Protects availability with topology spread, PDBs, zero-unavailable rollouts, and automated rollback.
- Hardens security with etcd encryption, PrivateLink endpoints, Kyverno admission policies, and immutable ECR tags.
- Promotes safely via Kustomize overlays (dev/staging/prod) and CI policy gates (Checkov, Trivy, kube-linter).

Core Architectural Decisions

- **Compute:** EKS managed node group provides a stable on-demand baseline; Karpenter bursts from pending pods and EC2 interruption signals.
- **Ingress:** Route 53, CloudFront, WAF, and ALB provide global entry, L7 filtering, TLS termination, health checks, and target deregistration.
- **Availability:** Pods and nodes are spread across three AZs; maxUnavailable is zero for deployments and PDB minAvailable is 80 percent.
- **State safety:** A DynamoDB idempotency table with PITR and KMS encryption prevents duplicate deductions during retries and partial failures.
- **Secrets and identity:** IRSA maps the Kubernetes service account to a narrow IAM role; secrets are pulled live from Secrets Manager via External Secrets Operator.
- **Registry:** ECR with immutable tags, KMS encryption, scan-on-push, and a node-only pull policy. Kyverno admission policy enforces ECR-only images and blocks latest/untagged/privileged containers.
- **Network isolation:** VPC PrivateLink endpoints (ECR API/DKR, STS, Secrets Manager) keep control-plane traffic off the public internet. NetworkPolicy restricts egress to the VPC CIDR only.
- **Multi-environment CI/CD:** Kustomize overlays (dev/staging/prod) carry per-env patches; Checkov, Trivy, and kube-linter run as mandatory pipeline gates before every kubectl apply.

Scalability Strategy

- HPA scales on CPU (60%), memory (70%), and Prometheus Adapter RPS (200 per pod).
- Karpenter launches right-sized EC2 capacity for unschedulable pods in private subnets.
- Baseline managed node group remains on-demand to avoid cold-start risk during flash sales.
- Per-environment HPA limits: dev (2-20), staging (3-60), prod (6-120).

Security and Networking

- Public exposure is limited to CloudFront, WAF, and ALB. Worker nodes remain in private subnets with egress through NAT gateways.
- IAM follows least privilege through IRSA. The service can only read its application secret, decrypt through the assigned KMS key, and write to the idempotency DynamoDB table.
- EKS etcd is encrypted with a customer-managed KMS key. Public API endpoint access is restricted to the corporate CIDR (10.0.0.0/8).
- VPC PrivateLink endpoints for ECR API, ECR DKR, STS, and Secrets Manager keep image pulls and credential calls inside the VPC. S3 and DynamoDB use Gateway endpoints (no data-transfer cost).
- Kyverno ClusterPolicy (Enforce mode) blocks any pod that uses a non-ECR registry, the latest tag, an untagged image, or privileged containers — admission-time rejection, not just audit.
- ECR uses IMMUTABLE tag mutability, scan-on-push with KMS encryption, a lifecycle policy retaining the last 10 images, and a repo policy limiting pull rights to the node IAM role.
- Kubernetes Pod Security Admission is set to restricted; containers run as non-root (UID 10001) with read-only filesystems and all Linux capabilities dropped.
- NetworkPolicy restricts ingress to the ALB security group and Prometheus scrape traffic only; egress is limited to the VPC CIDR (10.0.0.0/8) on port 443 and DNS.
- Control plane logs, audit logs, etcd encryption, and private endpoint access support defense in depth and incident investigation.

Reliability and Observability

Area	Measure	Recovery or Action
Availability	99.95% monthly SLO; ALB 5xx; successful deduction rate	Multi-AZ placement, PDB, automated rollback
Latency	p50, p95, p99 request latency by endpoint and region	Scale on load/latency, shed low-priority traffic if required
Errors	4xx/5xx rate, dependency failures, duplicate/idempotency conflicts	Rollback, circuit breakers, dependency failover runbooks
Capacity	CPU, memory, pending pods, node pressure, Karpenter provisioning time	HPA scale-up, Karpenter burst nodes, on-demand baseline
Business	Point deductions, failed deductions, retry success, revenue-impacting incidents	Page on burn rate and business KPI deviations

Failure Recovery

- **AZ outage:** Route traffic only to healthy ALB targets; topology spread and three-AZ node capacity keep replicas available.
- **Bad deployment:** Canary analysis checks error rate, latency, and business KPIs before promotion; failed canaries roll back automatically.
- **Node interruption:** Karpenter replacement capacity, PDBs, readiness gates, and graceful termination prevent request loss.
- **Dependency degradation:** Timeouts, retries with jitter, idempotency keys, and circuit breakers prevent retry storms and duplicate deductions.

Agile Delivery Framework (Scrum)

- **Cadence:** Four two-week sprints (8 weeks); each delivers a shippable increment aligned to one delivery phase.
- **Team & roles:** Senior SRE is Tech Lead / Scrum facilitator / PO-proxy; the two Juniors are the delivery developers, self-organising within each sprint.
- **Velocity:** ~26 pts/sprint (Senior ~8 review/enablement, each Junior ~9 delivery); re-baseline after Sprint 1.
- **Definition of Done:** PR merged with Senior approval; terraform validate/plan clean; kube-linter/Checkov/Trivy green; applied to dev overlay; runbook updated.

Sprint (2 weeks)	Sprint Goal	Senior SRE (Lead / Facilitator)	Junior 1 (Terraform & Platform)	Junior 2 (K8s & Observability)	Pts
Sprint 1 Foundation	Network, KMS, and EKS control plane stood up in dev with SLOs agreed and demoable.	• Facilitate planning; set SLOs • Review IAM / IRSA + encryption • Approve VPC / AZ design	• network, kms, eks modules • envs/*/backend.hcl + tfvars • init/plan smoke test per env	• base namespace, serviceaccount • deployment + service skeleton • ingress skeleton (placeholder WAF)	26
Sprint 2 Platform Add-ons	Karpenter, ESO, ALB controller, ECR, and Kyverno running in dev.	• Approve IRSA policies • Set Karpenter NodePool limits • Review Kyverno rules pre-Enforce	• sqs, iam, vpc-endpoints, ecr modules • addons: ALB, Karpenter, ESO, Kyverno	• hpa, pdb, networkpolicy • externalsecret, clustersecretstore • karpenter-nodepool, kyverno-policy	28
Sprint 3 Observability & Security	Golden-signal monitoring, burn-rate alerts, and CI policy gates live; security posture signed off.	• Review burn-rate thresholds vs SLOs • Sign off security posture • Author flash-sale / AZ runbooks	• addons: kube-prometheus-stack + adapter • Jenkins IaC gate (Checkov + Trivy) • .checkov.yaml justifications	• servicemonitor, prometheusrule • Grafana golden-signal dashboards • .kube-linter.yaml + K8s gate	26
Sprint 4 Multi-env & Handover	dev/staging/prod overlays promoted; game day run; on-call handover complete.	• Review overlays vs prod • Approve Jenkins ENV gate logic • Lead game day + on-call handover	• overlay karpenter-patch + kustomization • Jenkins ENV param + per-env plan • full-pipeline verification	• overlay deployment/hpa/ingress/externalsecret patches • smoke test kubectrl apply -k per overlay	26